Лекция 2. Комплексный подход к защите информации

1. Каналы утечки информации.
2. Комплексный подход к защите информации. Организационно-правовое и инженерно-техническое обеспечение информационной безопасности.
3. Криптографическая и программно-аппаратная защита информации.

Каналы утечки информации

Каналы утечки информации (способы несанкционированного ее получения) могут быть разделены на:

- косвенные или общедоступные (не связанные с физическим доступом к элементам КС);
- непосредственные или узко доступные (связанные с физическим доступом к элементам КС).

Косвенные каналы

- использование подслушивающих (радиозакладных) устройств;
- дистанционное видеонаблюдение;
- перехват побочных электромагнитных излучений и наводок (ПЭМИН).

ПЭМИ

- **Побочные электромагнитные излучения** или ПЭМИ создаются техническими средствами КС при обработке информации, существуют в диапазоне от единиц герц до 1,5 гигагерц и могут распространять обрабатываемую информацию.
- Наиболее опасными с точки зрения ПЭМИ являются дисплеи, кабельные линии связи, накопители на магнитных дисках.
- Для перехвата ПЭМИ используется специальная портативная (переносная) аппаратура.

ПЭМН

- **Побочные электромагнитные наводки** представляют собой сигналы в цепях электропитания и заземления аппаратных средств КС, а так же находящихся в зоне воздействия ПЭМИ работающих аппаратных средств КС, кабелях вспомогательных устройств (звукоусиления, связи, времени, сигнализации), металлических конструкциях зданий, сантехническом оборудовании.
- Эти наведенные сигналы могут выходить за пределы зоны безопасности КС.

Непосредственные каналы утечки, не требующие изменения элементов КС (без оставления следов)

- хищение носителей информации;
- сбор производственных отходов с информацией;
- намеренное копирование файлов других пользователей КС;
- чтение остаточной информации после выполнения заданий других пользователей (областей оперативной памяти, удаленных файлов, сохраненных временных файлов);
- копирование носителей информации;

Непосредственные каналы утечки, не требующие изменения элементов КС

- намеренное использование для несанкционированного доступа к информации незаблокированных терминалов других пользователей КС;
- маскировка под других пользователей путем похищения их идентифицирующей информации (паролей, карт и т.п.);
- обход средств разграничения доступа к информационным ресурсам вследствие недостатков в их программном обеспечении и др.

Непосредственные каналы утечки, предполагающие изменение элементов КС и ее структуры (с оставлением следов)

- незаконное подключение специальной регистрирующей аппаратуры к устройствам или линиям связи (пассивное для фиксации и сохранения передаваемых данных или активное для их уничтожения, искажения или подмены);
- умышленное изменение программ для выполнения ими несанкционированных действий (копирования или изменение информации при ее обработке, а также ее удаление);
- злоумышленный вывод из строя средств защиты информации.

Пассивное и активное подключение

- Пассивное подключение нарушителя к устройствам или линиям связи легко предотвратить (например, с помощью шифрования передаваемой информации), но невозможно обнаружить.
- Активное подключение, напротив, легко обнаружить (например, с помощью механизма электронной цифровой подписи), но невозможно предотвратить.

Необходимость комплексного подхода к защите информации

Поскольку наиболее опасные угрозы информационной безопасности вызваны преднамеренными действиями нарушителя, которые в общем случае являются неформальными,

защиты информации относится к формально не определенным проблемам.

Необходимость комплексного подхода к защите информации

1. Надежная защита информации в КС не может быть обеспечено только формальными методами (например, только программными и аппаратными средствами).
2. Защита информации в КС не может быть абсолютной.

Необходимость комплексного подхода к защите информации

Обеспечение информационной безопасности КС является непрерывным процессом, целенаправленно проводимым на всех этапах ее жизненного цикла с комплексным применением всех имеющихся методов и средств.

Основные группы методов и средств защиты информации

- методы и средства организационно-правовой защиты информации;
- методы и средства инженерно-технической защиты информации;
- криптографические методы и средства защиты информации;
- программно-аппаратные методы и средства защиты информации.

Организационно-правовое обеспечение информационной безопасности

Организационно-технические и организационно-правовые мероприятия, проводяться в процессе создания и эксплуатации КС для обеспечения защиты информации.

Основные свойства методов и средств организационной защиты

1. Обеспечивают полное или частичное перекрытие значительной части каналов утечки информации (например, хищения или копирования носителей информации);
2. Объединяют все используемые в КС методы и средства в целостный механизм защиты информации.

Содержание методов и средств организационной защиты информации

- ограничение физического доступа к объектам КС и реализация режимных мер;
- ограничение возможности перехвата ПЭМИН;
- разграничение доступа к информационным ресурсам и процессам КС (установка правил разграничения доступа, шифрование информации при ее хранении и передаче, обнаружение и уничтожение аппаратных и программных закладок);
- резервное копирование наиболее важных с точки зрения утраты массивов документов;
- профилактика заражения компьютерными вирусами.

Роль правового обеспечения

Основой проведения организационных мероприятий является использование и подготовка законодательных и нормативных документов в области информационной безопасности, которые на правовом уровне должны регулировать доступ к информации со стороны потребителей.

Уровни правового обеспечения информационной безопасности.

Первый уровень образуют международные договора, к которым присоединилась Российская Федерация, и федеральные законы России:

- международные (всемирные) конвенции об охране промышленной собственности, об охране интеллектуальной собственности, об авторском праве;
- Конституция РФ (статья 23 определяет право граждан на тайну переписки, телефонных, телеграфных и иных сообщений);

Уровни правового обеспечения информационной безопасности

- Гражданский кодекс РФ (в статье 139 устанавливается право на возмещение убытков от утечки с помощью незаконных методов информации, относящейся к служебной и коммерческой тайне);
- Уголовный кодекс РФ (статья 272 устанавливает ответственность за неправомерный доступ к компьютерной информации, статья 273 – за создание, использование и распространение вредоносных программ для ЭВМ, статья 274 – за нарушение правил эксплуатации ЭВМ, систем и сетей);

Уровни правового обеспечения информационной безопасности

- федеральный закон «Об информации, информационных технологиях и о защите информации»;
- федеральные законы «О государственной тайне», «О коммерческой тайне», «О персональных данных»;
- федеральные законы «О лицензировании отдельных видов деятельности», «О связи», «Об электронной цифровой подписи»;
- четвертая часть Гражданского кодекса РФ (охрана интеллектуальной собственности).

Уровни правового обеспечения информационной безопасности

Второй уровень правового регулирования защиты информации составляют подзаконные акты, к которым относятся указы Президента и постановления Правительства РФ, а также определения Конституционного суда РФ, письма Высшего арбитражного суда РФ и постановления пленумов Верховного суда РФ.

Уровни правового обеспечения информационной безопасности

Третий уровень правового обеспечения информационной безопасности составляют государственные стандарты (ГОСТы) в области защиты информации, руководящие документы, нормы, методики и классификаторы, разработанные соответствующими государственными органами.

Уровни правового обеспечения информационной безопасности

Четвертый уровень правового обеспечения информационной безопасности образуют локальные нормативные акты, положения, инструкции, методические рекомендации и другие документы по комплексной защите информации в КС конкретной организации.

Инженерно-технические средства защиты информации

- Физические объекты
- Механические, электрические и электронные устройства,
- Элементы конструкции зданий
- Средства пожаротушения и другие средства.

Назначение инженерно-технических средств защиты информации

- защита территории и помещений КС от проникновения нарушителей;
- защита аппаратных средств КС и носителей информации от хищения;
- предотвращение возможности удаленного (из-за пределов охраняемой территории) видеонаблюдения (подслушивания) за работой персонала и функционированием технических средств КС;

Назначение инженерно-технических средств защиты информации

- предотвращение возможности перехвата ПЭМИН, вызванных работающими техническими средствами КС и линиями передачи данных;
- организация доступа в помещения КС сотрудников организации;
- контроль над режимом работы персонала КС;
- контроль над перемещением сотрудников КС в различных производственных зонах;
- противопожарная защита помещений КС;
- минимизация материального ущерба от потерь информации, возникших в результате стихийных бедствий и техногенных аварий.

Технические средства охраны

Образуют первый рубеж защиты КС и включают в себя:

- средства контроля и управления доступом (СКУД);
- средства охранной сигнализации;
- Средства видеонаблюдения (охранного телевидения, CCTV).

Основы криптографической защиты информационных ресурсов

- К открытому тексту применяется функция шифрования, в результате чего получается шифротекст (или криптограмма).
- Для восстановления открытого текста из шифротекста к последнему применяется функция расшифрования.

Шифрование и расшифрование

Функции шифрования (E) и расшифрования (D) используют один или более дополнительных параметров, называемых ключом.

шифрование ключом K функция $\mathbf{E}_k$

P (открытый текст)--> C (шифротекст)

$C=E_k(P)$;

расшифрование ключом K' функция $\mathbf{D}_{k'}$

C (шифротекст) --> P (открытый текст)

$P=D_{k'}(C)$

Виды криптографических систем

- Если ключ шифрования K совпадает с ключом расшифрования K′, то такую криптосистему называют симметричной; если для шифрования и расшифрования используются разные ключи, то такую систему называют асимметричной.

- В симметричной криптосистеме ключ должен быть секретным; в асимметричной системе один из ключей может быть открытым.

Виды криптографических ключей

- Ключ симметричного шифрования обычно называют **сеансовым** (session key).
- Пару ключей асимметричного шифрования образуют **открытый** ключ (public key) и **личный** (или закрытый) ключ (secret key, private key).

Криптография и криптоанализ

- Науку о защите информации с помощью шифрования называют **криптографией**.
- Процесс получения открытого текста из шифротекста без знания ключа расшифрования называют обычно **дешифрованием** (или «»взломом» шифра), а науку о методах дешифрования – **криптоанализом**.
- Совместным изучением методов криптографии и криптоанализа занимается **криптология**.

Криптостойкость

Характеристика надежности шифротекста от вскрытия называется **криптостойкостью**. Криптостойкость шифра может оцениваться двумя величинами:

- минимальным объемом шифротекста, статистическим анализом которого можно его вскрыть и получить открытый текст без знания ключа;
- количеством MIPS-часов или MIPS-лет – времени работы условного криптоаналитического компьютера производительностью один миллион операций в секунду, необходимой для вскрытия шифротекста.

Применение криптографических методов защиты информации

- Обеспечение конфиденциальности информации, передаваемой по открытым линиям связи или хранящейся на открытых носителях информации.
- Аутентификация, обеспечение целостности и неоспоримости передаваемой информации.
- Защита информационных ресурсов от несанкционированного использования.

Хеширование информации

- **Хешированием** информации называют процесс ее преобразования в хеш-значение фиксированной длины (дайджест, образ, хеш-код или просто хеш).
- **Функция хэширования** (хэш-функция) представляет собой преобразование, на вход которого подается сообщение переменной длины M, а выходом является строка фиксированной длины h(M).

Понятие функции хеширования

- Хэш-значение h(M) - это дайджест сообщения M, т. е. сжатое двоичное представление основного сообщения M произвольной длины. Иначе говоря, хэш-функция h(.) принимает в качестве аргумента сообщение (документ) M произвольной длины и возвращает хэш-значение (хэш) H=h(M) фиксированной длины.
- Функция хэширования позволяет сжать подписываемый документ M до 128 и более бит (в частности до 128 или 256 бит), тогда как M может быть размером в мегабайт или более. Следует отметить, что значение хэш-функции h(M) зависит сложным образом от документа M и не позволяет восстановить сам документ M.

Применение функций хеширования

- Хранение образов паролей пользователей компьютерных систем в регистрационных базах данных.
- Генерация одноразовых паролей и откликов на случайные запросы службы аутентификации.
- Обеспечение подлинности и целостности электронных документов.

Аппаратные средства защиты информации

Электронные и электронно-механические устройства, включаемые в состав технических средств КС и выполняющие (самостоятельно или в едином комплексе с программными средствами) некоторые функции обеспечения информационной безопасности.

Критерием отнесения устройства к аппаратным, а не инженерно-техническим средствам защиты является именно обязательное включение в состав технических средств КС.

Основные аппаратные средства защиты информации

- устройства для ввода идентифицирующей пользователя информации (магнитных и пластиковых карт, отпечатков пальцев и т.п.);
- устройства для хранения идентифицирующей пользователя информации (карты, генераторы одноразовых паролей, элементы Touch Memory и т.п.);
- устройства для шифрования информации;
- устройства для воспрепятствования несанкционированному включению рабочих станций и серверов (электронные замки и блокираторы).

Вспомогательные аппаратные средства защиты информации

- устройства уничтожения информации на магнитных носителях;
- устройства сигнализации о попытках несанкционированных действий пользователей КС и др.

Программные средства защиты информации

Специальные программы, включаемые в состав программного обеспечения КС исключительно для выполнения защитных функций. К основным программным средствам защиты информации относятся:

- программы идентификации и аутентификации пользователей КС;
- программы разграничения доступа пользователей к ресурсам КС;
- программы шифрования информации;
- программы защиты информационных ресурсов (системного и прикладного программного обеспечения, баз данных, компьютерных средств обучения и т.п.) от несанкционированного изменения, использования и копирования.

Идентификация и аутентификация

- Под **идентификацией**, применительно к обеспечению информационной безопасности КС, понимают однозначное распознавание уникального имени субъекта КС (проверка его регистрации в системе).
- **Аутентификация** при этом означает подтверждение того, что предъявленное имя соответствует данному субъекту (подтверждение подлинности субъекта).

Вспомогательные программные средства защиты информации

- программы уничтожения остаточной информации (в блоках оперативной памяти, временных файлах и т.п.);
- программы аудита (ведения регистрационных журналов) событий, связанных с безопасностью КС, для обеспечения возможности восстановить и доказать факт происшествия этих событий;
- программы имитации работы с нарушителем (отвлечения его на получение якобы конфиденциальной информации);
- программы тестового контроля защищенности КС и др.

Преимущества и недостатки программных средств защиты информации

- Простота тиражирования.
- Гибкость.
- Простота использования.
- Неограниченные возможности развития.
- Расходование ресурсов компьютерных систем.
- Возможность обхода (из-за «пристыкованности»).
- Возможность злоумышленного изменения.